# Literature Survey Report: Privacy Preserving KYC

Vundela Obula Reddy, Kishore Senthilkumar, Cezan Vispi Damania, and Srijani Gadupudi

Department of Computer Science and Engineering, IIT Kanpur
CS670: Cryptographic Techniques for Privacy Preservation

November 1, 2026

**Video Presentation**

**Abstract**

This report presents a preliminary literature survey for the "Privacy Preserving KYC" project, exploring various cryptographic techniques and their real-world applications. The survey is divided into four main domains, each investigated by a team member to cover a comprehensive breadth of the current research landscape.

## 1 KYC Foundations, Requirements, and the Privacy-Preserving KYC Problem Space

*Prepared by: Vundela Obula Reddy*

This section establishes the foundational principles of Know Your Customer (KYC) regulations and delineates the inherent conflict between stringent compliance mandates and user data privacy. We explore the cryptographic and architectural requirements necessary to resolve this tension, specifically focusing on data minimization, unlinkability, and Self-Sovereign Identity (SSI) paradigms.

### 1.1 Designing a Framework for Digital KYC Processes Built on Blockchain-Based Self-Sovereign Identity

**Problem Statement:** Traditional KYC processes in financial institutions are highly redundant, cost-intensive, and prone to creating centralized data silos that compromise user privacy. While blockchain technology is frequently proposed as a solution, storing personally identifiable information on an immutable public ledger directly violates modern data protection regulations.

**Proposed Solution & Methodology:** The authors utilize a rigorous design science research methodology to propose a framework based on Self-Sovereign Identity (SSI).

The framework completely decouples identity data from the blockchain. The blockchain is strictly restricted to acting as an anchoring layer for Decentralized Identifiers (DIDs) and credential revocation registries, ensuring that no personal data is stored on-chain. This approach eliminates lock-in effects and data silos while satisfying strict regulatory compliance.

### 1.2 KYChain: User-Controlled KYC Data Sharing and Certification

**Problem Statement:** During client on-boarding, institutions struggle to efficiently verify the trustworthiness of new clients without forcing them to repeatedly submit redundant documentation.

**Proposed Solution & Methodology:** Drăgan proposes KYChain, a privacy-preserving certification protocol that allows clients to securely share up-to-date, certified KYC data across multiple financial entities. The methodology employs an immutable ledger to store cryptographic hashes of encrypted KYC certificates, while the actual encrypted data is maintained in off-chain storage. Clients retain full control over their decryption keys, enabling them to selectively grant access to chosen institutions, thereby accelerating onboarding while maintaining strict data confidentiality.

### 1.3 Privacy-Preserving KYC on Ethereum

**Problem Statement:** In standard decentralized applications, users are forced to choose between remaining anonymous (and unregulated) or exposing their entire transaction history and asset balances to a centralized identity provider during KYC verification.

**Proposed Solution & Methodology:** Biryukov et al. propose a KYC-compliant identity scheme on Ethereum utilizing Merkle trees and smart contracts to ensure unlinkability. In this model, the user, rather than the KYC provider, is responsible for cryptographically linking their wallet accounts to their certified identity. The scheme ensures that the association between specific wallet addresses and the certified identity remains hidden from the public and the identity provider, preserving financial privacy while retaining a mechanism for legal deanonymization by supervisors in cases of illicit activity.

## 2 Zero-Knowledge Proofs in Privacy-Preserving KYC

*Prepared by: Kishore*

This section investigates how Zero-Knowledge Proofs (ZKPs) resolve the core tension between regulatory compliance and user data privacy in Know Your Customer (KYC) systems. We explore how cryptographic constructs—specifically non-interactive zero-knowledge arguments, trusted-setup-free range proofs, and commit-and-prove architectures—enable the validation of identity attributes, credentials, and compliance policies without disclosing underlying personally identifiable information (PII).

## 2.1 zkKYC: A Solution Concept for KYC Without Knowing Your Customer

**Problem Statement:** Traditional KYC and AML/CTF compliance models mandate that users disclose raw identity documents to every onboarding business. This creates centralized data honeypots prone to breaches (the Copy Problem), prevents users from sharing only required attributes (the Bundling Problem), and offers weak governance protections over replicated data (the Recursive Oversight Problem).

**Proposed Solution & Methodology:** The author proposes a conceptual framework combining Self-Sovereign Identity (SSI) with Zero-Knowledge Proofs to decouple regulatory verification from data collection. Users hold credentials issued by trusted authorities and provide businesses with a three-part package: a zero-knowledge eligibility proof, a zero-knowledge validity proof, and an encrypted zkKYC token readable only by regulatory authorities. This circular architecture ensures that businesses verify compliance without accessing personal data, while preserving lawful de-anonymization and auditability via the regulator's decryption key in cases of suspected financial crime.

## 2.2 Bulletproofs: Short Proofs for Confidential Transactions and More

**Problem Statement:** Verifying continuous attributes in privacy-preserving KYC (e.g., verifying age thresholds, income brackets, or credit risk scores) fundamentally relies on range proofs over committed values. However, prior zero-knowledge proof systems either required complex and vulnerable trusted parameter setup ceremonies (toxic waste) or produced proofs that scaled linearly with witness bit length, resulting in prohibitive transmission overhead.

**Proposed Solution & Methodology:** The authors introduce Bulletproofs, a non-interactive zero-knowledge argument system that eliminates trusted setups entirely by relying solely on the Discrete Logarithm assumption over standard elliptic curve groups. Using an optimized recursive inner-product argument, Bulletproofs reduces range proof size from linear to logarithmic order ($2\log_2(n) + 9$ group and field elements). Furthermore, the protocol natively supports multi-proof aggregation, allowing multiple identity attributes to be proven simultaneously in a single compact proof with minimal marginal size increases.

## 2.3 Privacy-Preserving On-Chain Permissioning for KYC Compliant Decentralized Applications

**Problem Statement:** Decentralized applications (dApps) in DeFi require robust on-chain compliance mechanisms, yet evaluating high-dimensional identity credentials and signature verification directly inside smart contract virtual machines incurs severe computational and gas costs. Additionally, relying on centralized whitelisting undermines decentralization and creates user surveillance vectors.

**Proposed Solution & Methodology:** The authors present an end-to-end framework integrating SSI, zk-SNARKs, and Attribute-Based Access Control (ABAC) to enforce KYC permissioning directly through smart contracts. To minimize on-chain execution costs, the framework adopts a commit-and-prove scheme that verifies credential authenticity outside

the ZKP circuit while the circuit strictly evaluates mathematical policy predicates (such as range, equality, time-dependent, and Merkle-tree set-membership proofs). This allows on-chain smart contracts to transparently enforce regulatory policies while preserving complete attribute privacy.

# 3 Anonymous Credentials & Attribute-Based Cryptography

*Prepared by: Cezan*

This section investigates the credential-issuance and access-control primitives required for privacy-preserving KYC systems. Specifically, it explores how trusted identity issuers can certify user attributes using anonymous credentials (such as CL-signatures) to enable unlinkable selective disclosure, and how Attribute-Based Encryption (ABE) can enforce fine-grained access policies over stored KYC data at rest.

## 3.1 An Efficient System for Non-transferable Anonymous Credentials with Optional Anonymity Revocation

**Problem Statement:** Traditional digital certificate systems (such as standard PKI) rely on static public key signatures. When users present these certificates to verifiers to prove identity claims, the static identifiers allow malicious verifiers to track and link user transactions across different services, compromising user privacy during repeated KYC verifications.

**Proposed Solution & Methodology:** Camenisch and Lysyanskaya introduce the foundational Camenisch-Lysyanskaya (CL) signature scheme over secret commitments. The framework enables a user to obtain a signed credential containing multiple attributes from a trusted issuer. When proving facts to a verifier, the user generates a Zero-Knowledge Proof of Knowledge (ZKPK) of the signature without revealing the signature itself or the raw attributes. This guarantees multi-show unlinkability, allowing a user to undergo KYC checks repeatedly without exposing a trackable digital footprint, while incorporating an optional trustee-based anonymity revocation mechanism to remain compliant with anti-money laundering (AML) regulations.

## 3.2 Ciphertext-Policy Attribute-Based Encryption

**Problem Statement:** Traditional data-at-rest encryption relies on public-key infrastructure or symmetric keys, requiring data to be encrypted for specific recipient identities. In enterprise KYC management, storing sensitive identity documents under static keys creates vulnerable central honeypots and lacks the granularity required to enforce complex, role-based compliance policies across internal auditors.

**Proposed Solution & Methodology:** Bethencourt, Sahai, and Waters propose Ciphertext-Policy Attribute-Based Encryption (CP-ABE), shifting data protection from identity-centric to policy-centric mechanisms. In CP-ABE, encrypted KYC documents are bound directly to a access tree representing an arbitrary Boolean policy
(e.g., $(\text{Role} = \text{ComplianceOfficer} \wedge \text{Region} = \text{EU}) \vee \text{RiskTier} = \text{High}$). Users are issued

secret keys associated with sets of attributes; a user can only decrypt the stored KYC file if their attributes satisfy the ciphertext's access policy tree. This ensures cryptographically enforced access control over stored identity records.

### 3.3 Compact and Selective Disclosure for Verifiable Credentials

**Problem Statement:** Modern standards for selective disclosure in Verifiable Credentials (such as SD-JWT) require transmitting lists of salted hashes for every claim contained within a credential. On resource-constrained mobile hardware wallets or during bandwidth-sensitive eID transactions (such as European Digital Identity / EUDI Wallet flows), this structural overhead leads to excessive memory usage and large Verifiable Presentation (VP) payload sizes.

**Proposed Solution & Methodology:** Buldini et al. propose CSD-JWT, a compact selective disclosure mechanism for Verifiable Credentials that replaces full lists of salted hashes with a single, constant-length cryptographic accumulator digest. By accumulating all credential claims into a fixed-length representation, the credential size remains constant regardless of the number of claims. The authors implement CSD-JWT as an open-source solution, demonstrating that it reduces credential storage memory usage by up to 46% and decreases Verifiable Presentation network payload sizes by 27% to 93%, making it highly suitable for constrained hardware wallets in modern SSI architectures.

## 4 Secure Multi-Party Computation, Homomorphic Encryption and Compliance Infractructure

*Prepared by: Srijani*

This section investigates the cryptographic and architectural techniques that enable privacy-preserving computation and compliance enforcement in KYC systems. While privacy-preserving KYC requires sensitive identity and financial information to remain confidential, KYC processes also require multiple organizations to collaboratively analyze and verify information. This creates the challenge of performing useful computations on sensitive data while preventing participating parties from accessing each other's raw data. We explore Secure Multi-Party Computation (MPC) and Homomorphic Encryption (HE) as techniques for performing computations while preserving the confidentiality of KYC data. The section also examines how these cryptographic techniques can be integrated with blockchain-based infrastructure, access control, consent mechanisms, and auditability to support practical and compliant KYC systems.

### 4.1 Secure Multi-Party Computation for Cross-Institutional AML Risk Detection

**Problem Statement:** Detecting money laundering requires analyzing transaction patterns that span multiple banks' customer bases, since a laundering scheme is often only visible when transactions across several institutions are viewed together. No single bank holds this full picture, and banking-secrecy law prohibits banks from sharing raw customer transaction data with each other to close that gap. This is a KYC problem, not just an

AML one: KYC identity data underlies the transaction graph, and banks are obligated to continuously monitor that graph as an extension of onboarding-time verification.

**Proposed Solution & Methodology (van Egmond et al.):** The paper uses **secure multi-party computation (MPC)**, a method that lets multiple parties jointly compute a result over their combined data without any party seeing another party's raw data. This works through **secret sharing**: each bank splits its transaction data into randomized numerical fragments, distributed across the computing parties. No single fragment reveals anything about the original value on its own, but the fragments can be combined mathematically during computation to produce a correct final result. Using this, banks jointly run a risk-propagation algorithm, where a risk score starts at flagged accounts and spreads outward through the transaction graph, first to the accounts they transacted with, then to the accounts those transacted with, and so on. Only the final risk scores are revealed at the end and the underlying transaction data is never reassembled by any single party. Tested on real transaction data, confirming cross-bank laundering patterns can be detected without exposing raw data between the two banks.

## 4.2 Homomorphic Encryption for Computing on Encrypted KYC and Biometric Data

**Problem Statement:** KYC systems need to perform computations on sensitive data like numeric risk scores, or biometric templates like fingerprints and iris scans used during identity verification but without exposing that data to whichever party runs the computation. This is especially critical for biometrics since a leak would be permanent unlike passwords where we can change or reissue. Choosing a cryptographic method to compute on this data while it stays encrypted is difficult since existing techniques may be computation heavy and cost incurring.

**Proposed Solution & Methodology (Acar et al.; HE-for-biometrics review):** Both papers center on **homomorphic encryption (HE)**, a form of encryption where mathematical operations (addition, multiplication) can be performed directly on the encrypted data, and decrypting the result gives the same answer as if the operations had been done on the original unencrypted data. Acar et al. classify HE into three types by how many operations they support:

- **Partially homomorphic encryption (PHE):** supports only one operation (e.g., only addition) but an unlimited number of times.
- **Somewhat homomorphic encryption (SHE):** supports both addition and multiplication, but only a limited number of times before the result becomes corrupted by accumulated errors in the ciphertext.
- **Fully homomorphic encryption (FHE):** supports unlimited operations of both types using **bootstrapping**, a process that resets the accumulated errors in a ciphertext by running the decryption process on it homomorphically, without ever revealing the plaintext.

Both the stored template and the new scan of the biometric are encrypted and the system computes their similarity using Euclidean distance or Hamming distance. Only the result (match or no-match) is decrypted. The data itself is never exposed at any point in the verification process.

### 4.3 Attribute-Based Access Control on Blockchain for Compliant, Auditable KYC

**Problem Statement:** Sharing KYC data across parties requires two things at once:

- **Fine-grained access control:** a requester should see only the specific data they are authorized for, not an entire record.
- **A permanent, tamper-evident record:** a log of who accessed what data and under what authorization.

A centralized database is a single point of failure for breaches, and writing plaintext KYC data directly onto a blockchain permanently exposes personal data on a public ledger that cannot be edited or deleted. A separate but related problem is that KYC compliance status is not static, for example, a customer's risk classification can change after their credential is issued, and most credential systems require a full reissuance to reflect any such change.

**Proposed Solution & Methodology (Fugkeaw; REGKYC):**

**The old way (what CP-ABE replaces):** Normally, if you want to give 5 different people access to the same encrypted file, you would need to encrypt a separate copy for each person's individual key, or maintain a large access-control list mapping specific people to specific keys. This is clunky to manage, especially as new employees join, leave, or change roles.

**How CP-ABE is better:** The data is encrypted once and locked under a policy expressed as a rule over attributes, for example "role = compliance-officer AND jurisdiction = EU," rather than a rule over specific people. Each person is issued a key that reflects which attributes they hold, rather than a key tied to their individual identity. When someone tries to decrypt the file, the system checks whether their attribute-key values satisfy the policy attached to the ciphertext. The check is enforced by the cryptography itself rather than a separate access-control server. This means a bank does not need to know in advance exactly which individuals will need to view a given KYC record, the data never needs to be re-encrypted for each new person. When someone needs their access revoked, their keys need to be invalidated. This can be handled via time bounds by incorporating the time period into the key and the time period also needs to match along with the roles to allow decryption.

# References


- Biryukov, A., Khovratovich, D., & Tikhomirov, S. (2018). Privacy-preserving KYC on Ethereum. In *Proceedings of the 2018 International Conference on Software Engineering and Application (ESSE '18)* (pp. 28–34). ACM. https://doi.org/10.1145/3278158.3278160
- Drăgan, C. C. (2020). KYChain: User-Controlled KYC Data Sharing and Certification. *arXiv*. https://arxiv.org/abs/2001.01659
- Schlatt, V., Sedimeir, J., Feulner, S., & Urbach, N. (2022). Designing a Framework for Digital KYC Processes Built on Blockchain-Based Self-Sovereign Identity. *Information & Management*. https://arxiv.org/abs/2112.01237

- Bethencourt, J., Sahai, A., & Waters, B. (2007). Ciphertext-Policy Attribute-Based Encryption. In *2007 IEEE Symposium on Security and Privacy (S&P'07)* (pp. 321-334). https://doi.org/10.1109/SP.2007.11
- Buldini, A., Mazzocca, C., Montanari, R., & Uluagac, S. (2025). Compact and Selective Disclosure for Verifiable Credentials. *arXiv preprint arXiv:2506.00262*. https://doi.org/10.48550/arXiv.250600262
- Camenisch, J., & Lysyanskaya, A. (2001). An Efficient System for Non-transferable Anonymous Credentials with Optional Anonymity Revocation. In *International Conference on the Theory and Applications of Cryptographic Techniques (EUROCRYPT 2001)* (pp. 93-118). Springer, Berlin, Heidelberg. https://doi.org/10.1007/3-540-44987-X_7
- van Egmond, M.B., Dunning, V., van den Berg, S., Rooijakkers, T., Sangers, A., Poppe, T., & Veldsink, J. (2024). Privacy-preserving Anti-Money Laundering using Secure Multi-Party Computation. *IACR ePrint Archive*, Paper 2024/065. https://eprint.iacr.org/2024/065
- Acar, A., Aksu, H., Uluagac, A.S., & Conti, M. (2018). A Survey on Homomorphic Encryption Schemes: Theory and Implementation. *ACM Computing Surveys*, 51(4), Article 79. https://doi.org/10.1145/3214303
- Yang, W., Wang, S., Cui, H., Tang, Z., & Li, Y. (2023). A Review of Homomorphic Encryption for Privacy-Preserving Biometrics. *Sensors*, 23(7), 3566. https://doi.org/10.3390/s23073566
- Fugkeaw, S. (2022). Enabling Trust and Privacy-Preserving e-KYC System Using Blockchain. *IEEE Access*, 10, 49028–49039. https://doi.org/10.1109/ACCESS.2022.3172973
- Xiong, X., Huth, M., & Knottenbelt, W. (2025). REGKYC: Supporting Privacy and Compliance Enforcement for KYC in Blockchains. *IACR ePrint Archive*, Paper 2025/579. https://eprint.iacr.org/2025/579
- Pauwels, P. (2021). zkKYC: A solution concept for KYC without knowing your customer, leveraging self-sovereign identity and zero-knowledge proofs. *IACR Cryptology ePrint Archive*, Report 2021/907. https://eprint.iacr.org/2021/907
- Bünz, B., Bootle, J., Boneh, D., Poelstra, A., Wuille, P., & Maxwell, G. (2018). Bulletproofs: Short proofs for confidential transactions and more. In *2018 IEEE Symposium on Security and Privacy (SP)* (pp. 315–334). IEEE. https://doi.org/10.1109/SP.2018.00020
- Piper, F., Wolf, K., & Heiss, J. (2025). Privacy-Preserving On-chain Permissioning for KYC-Compliant Decentralized Applications. *arXiv preprint arXiv:2510.05807*. https://doi.org/10.48550/arxiv.2510.05807